Azure Key Vault — Task 1

RBAC-enabled Key Vault and first secrets · Completed 5 November 2026

The hospital's lab secrets (service passwords, API keys) should not live in scripts, .env files or GitHub. Task 1 creates a central, access-controlled vault for them and stores the first two dummy secrets.

Prepared By	Sabitha S Karanavar
Date	November 5, 2026
Tool	Azure CLI script `task1_create_vault.sh` (dry run by default, `--apply` to create)
Branch	`feature/azure-key-vault-setup` (learning/README.md Entry 2)
Cost	Standard tier: no monthly fee, about $0.03 per 10,000 operations (effectively $0 for this lab)

Summary

#	Step	Status
1	Register the Microsoft.KeyVault resource provider (free, one time)	✅ Done
2	Create resource group HVMC-KeyVault-RG (East US) with project tags	✅ Done
3	Create vault hvmc-accessguard-kv: Standard, Azure RBAC, soft delete 7 days, purge protection	✅ Done
4	Give the IAM admin **Key Vault Secrets Officer** on this vault only	✅ Done
5	Store 2 dummy secrets with random values (never printed)	✅ Done
6	Proof: vault settings, masked secrets, role list, portal screenshot	✅ Done

1. Why Azure Key Vault for AccessGuard Health

Problem today	What the vault gives
Passwords and API keys written in scripts or .env files	One central store; scripts ask the vault at run time
Anyone with the file can read the secret	Access controlled by Entra ID identities and roles
No record of who read a secret	Audit logs of every secret read (Task 3)
A deleted secret is gone	Soft delete + purge protection: deleted secrets can be recovered

The vault uses the **Azure RBAC** permission model, so Key Vault access follows the same group-based, least-privilege design as the Week 1 RBAC matrix (Task 2 maps the groups to Key Vault roles).

2. What was built

Item	Setting	Why
Resource group	HVMC-KeyVault-RG, East US, tags project=HVMC-AccessGuard, purpose=learning-keyvault, data=dummy-only	Kept separate from the SecOps lab so it is easy to find, cost and clean up
Vault	hvmc-accessguard-kv, **Standard** tier	No monthly fee; Premium (HSM keys) not needed for secrets
Permission model	**Azure RBAC** (no legacy access policies)	Same roles and groups as the rest of the project
Soft delete	On, 7-day retention	A deleted secret can be recovered for 7 days
Purge protection	**On** (cannot be turned off)	Nobody, not even an admin, can permanently destroy a secret early
My access	Key Vault Secrets Officer, **vault scope only**	Least privilege: not the whole subscription
Secrets	servicenow-lab-password, accessguard-api-key	Random dummy values only, no real data

3. Proof: vault settings

```
$ az keyvault show -n hvmc-accessguard-kv --query "{...}" -o table
Name                 Sku       RbacAuthorization    SoftDelete    RetentionDays    PurgeProtection
-------------------  --------  -------------------  ------------  ---------------  -----------------
hvmc-accessguard-kv  standard  True                 True          7                True
```

RBAC authorization, soft delete and purge protection are all **True**, which meets the Task 1 success criteria.

4. Proof: secrets stored (values masked)

```
$ az keyvault secret show --vault-name hvmc-accessguard-kv -n servicenow-lab-password
{
  "contentType": "dummy lab value",
  "created": "2026-11-05T17:41:19+00:00",
  "enabled": true,
  "name": "servicenow-lab-password",
  "value": "********  (masked, 32 chars)"
}

$ az keyvault secret show --vault-name hvmc-accessguard-kv -n accessguard-api-key
{
  "contentType": "dummy lab value",
  "created": "2026-11-05T17:41:20+00:00",
  "enabled": true,
  "name": "accessguard-api-key",
  "value": "********  (masked, 32 chars)"
}
```

5. Proof: who has access

```
$ az role assignment list --scope <vault-id> --query "[].{role:roleDefinitionName}" -o table
Role
--------------------------
Key Vault Secrets Officer
```

Only one role on the vault: the IAM admin as **Key Vault Secrets Officer**. Task 2 adds the Administrator, Reader and Secrets User groups.

6. Portal view

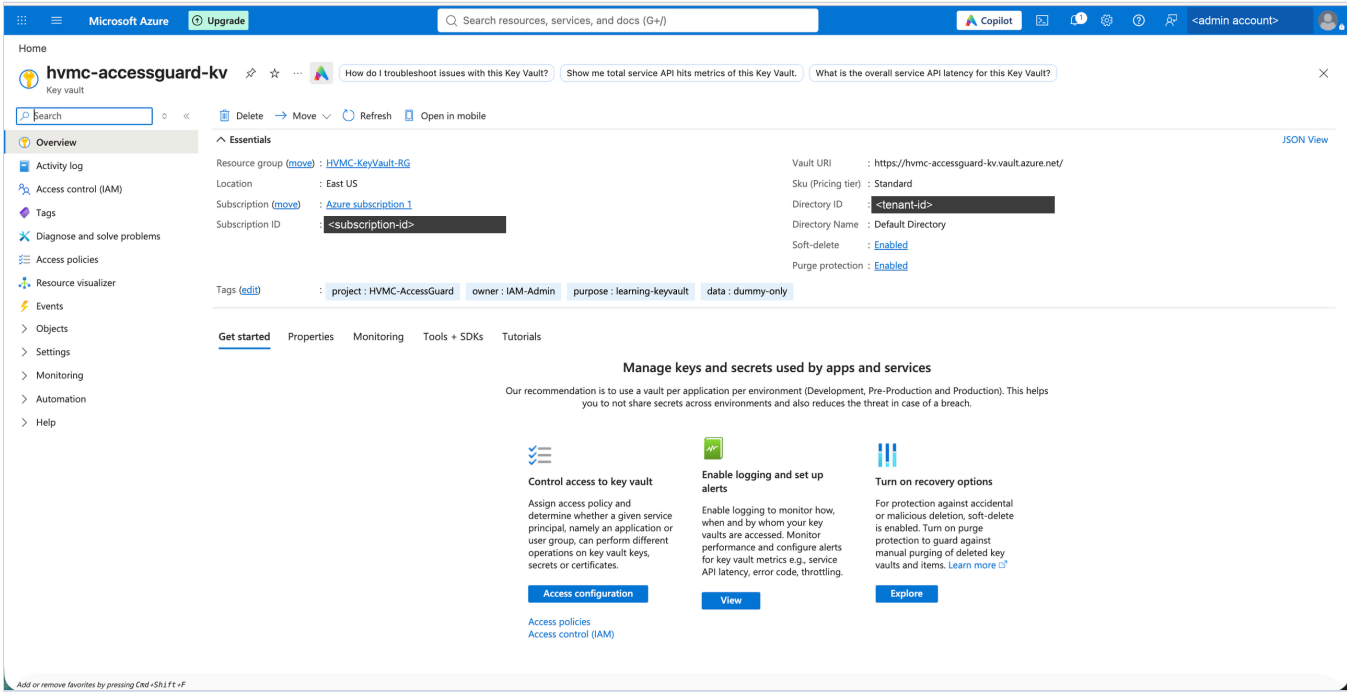


Figure 1. hvmc-accessguard-kv in the Azure portal (subscription and tenant details masked).

7. How secret values were kept safe

Risk	Control used
Secret visible on the command line or in shell history	Value written to a temporary file readable only by me (chmod 600) and uploaded with `--file`
Secret left on disk	Temporary file deleted straight after the upload
Secret visible in proof or GitHub	Proof output masks the value; only names, dates and settings are shown
Script changes things by mistake	Dry run by default; `--apply` needed to create anything

8. Challenges and how I solved them

Challenge	Cause	Fix
No active subscription	The free trial had ended; a new subscription needs an upgraded account	Saved a read-only evidence snapshot, upgraded with the free Basic support plan, then set a $10/month budget with alerts, paused the flow log, capped Log Analytics, and removed only the NAT gateway, load balancer and their public IPs

Challenge	Cause	Fix
Azure stayed read-only ~8 minutes after the upgrade	ReadOnlyDisabledSubscription while the upgrade finished	The script is safe to re-run, so I retried until it worked
Owner could not write secrets	With RBAC, Owner manages the vault (control plane) but not the secrets (data plane)	Gave myself Key Vault Secrets Officer on this vault only and waited about a minute

> **Key lesson.** In Azure RBAC, managing a resource and reading the data inside it are separate permissions. Being Owner of the subscription does not let you read a secret — the same separation of duties a hospital needs between IT administrators and the people who use the credentials.

9. Next steps

Task	What	Target
Task 2	Map groups to Key Vault Administrator / Reader / Secrets User; prove the Reader is denied secret values	10 Nov
Task 3	Read a secret from Python with DefaultAzureCredential (no hardcoded secret); audit logs to Log Analytics (SecretGet)	16 Nov
Later	Network hardening (firewall / private endpoint); HashiCorp Vault as the next phase	Out of scope this month